NEXTREPORTING

DATA PROCESSING AGREEMENT (DPA)

Version 1.0

1. PURPOSE

This Data Processing Agreement (the "**DPA**") forms an integral part of the General Subscription Terms and Conditions entered into between the Provider and the Customer (the "**Agreement**").

The purpose of this DPA is to establish the conditions under which the Provider processes Personal Data on behalf of the Customer in connection with the provision of the NEXTREPORTING Software as a Service platform and any related Professional Services.

The Parties acknowledge that, in relation to the Processing of Personal Data governed by this DPA, the Customer acts as Controller and the Provider acts as Processor within the meaning of Regulation (EU) 2016/679 ("**GDPR**"), unless expressly agreed otherwise in writing with respect to a specific Processing activity. Nothing contained in this DPA shall prevent the Provider from acting as an independent Controller in relation to Personal Data processed for its own legitimate business purposes, including customer relationship management, invoicing, legal compliance, fraud prevention, network security and the management of its contractual relationship with the Customer.

2. SCOPE OF PROCESSING

The Provider shall Process Personal Data solely for the purpose of providing the Services described in the Agreement and strictly in accordance with the documented instructions of the Customer.

The Parties acknowledge that the nature of the Service necessarily requires the Provider to host, organise, store, retrieve, analyse, transmit and otherwise Process Personal Data made available through the Service or received through authorised integrations with third-party systems designated by the Customer.

The categories of Data Subjects, the categories of Personal Data, the nature of the Processing operations and the purposes of the Processing are described in **Annex I**, which forms an integral part of this DPA.

Should the Customer require Processing activities materially different from those described in Annex I, the Parties shall agree upon such Processing in writing before implementation.

3. PROCESSING INSTRUCTIONS

The Provider shall Process Personal Data exclusively on documented instructions received from the Customer, including those reflected in the Agreement, the applicable Order Form, this DPA and any subsequent written instructions agreed between the Parties.

If the Provider considers that an instruction infringes applicable Data Protection Law, it shall promptly inform the Customer and may suspend the implementation of such instruction until the Customer confirms, modifies or withdraws it.

The Provider shall not be required to follow any instruction which, in its reasonable opinion, would expose the Provider to a breach of applicable law, regulatory requirements or legally binding orders issued by competent authorities.

Where the Provider is required under applicable law to Process Personal Data otherwise than pursuant to the Customer's instructions, it shall inform the Customer before carrying out such Processing unless prohibited by law on important grounds of public interest.

The Customer acknowledges that general instructions regarding the operation of the Service may be implemented through configuration settings selected directly by the Customer or its Authorised Users.

4. CONFIDENTIALITY

The Provider shall ensure that every individual authorised to Process Personal Data is bound by an appropriate contractual or statutory duty of confidentiality.

Access to Personal Data shall be strictly limited to those members of personnel who require such access for the performance of their assigned responsibilities.

The Provider shall maintain internal procedures designed to ensure that confidentiality obligations continue to apply after termination of employment or contractual engagement.

The Provider shall regularly remind relevant personnel of their confidentiality obligations and shall implement appropriate disciplinary measures in the event of unauthorised disclosure.

5. SECURITY OF PROCESSING

Taking into account the state of the art, the costs of implementation, the nature, scope, context and purposes of the Processing, together with the risks of varying likelihood and severity for the rights and freedoms of natural persons, the Provider shall implement and maintain appropriate technical and organisational measures designed to ensure a level of security appropriate to the risks presented by the Processing.

Such measures shall be continuously reviewed throughout the duration of the Agreement and may be updated by the Provider provided that the overall level of protection is not materially reduced.

Without limiting the foregoing, the Provider shall maintain a comprehensive information security programme, which may address, among others matters: governance, access management, authentication, encryption, system monitoring, vulnerability management, malware protection, secure software development, backup management, business continuity, disaster recovery, incident response and physical security.

The specific security measures implemented by the Provider are described in **Annex II**, which may be updated from time to time to reflect technological developments, recognised industry standards and evolving cybersecurity risks.

The Provider shall not materially reduce the level of protection described in Annex II without prior notice to the Customer.

6. ASSISTANCE TO THE CUSTOMER

The Provider shall provide reasonable assistance to enable the Customer to comply with its obligations under applicable Data Protection Law, taking into account the nature of the Processing and the information available to the Provider.

Such assistance shall include, where reasonably necessary, support in responding to requests from Data Subjects, cooperation in relation to supervisory authority investigations, assistance in conducting data protection impact assessments and support in consultations with competent supervisory authorities where required by law.

The Provider shall not respond directly to requests received from Data Subjects unless legally required to do so or expressly authorised by the Customer.
Where legally permissible, the Provider shall promptly notify the Customer upon receipt of any request, complaint, enquiry or investigation relating to Personal Data Processed under this DPA.

Where assistance requires substantial additional resources beyond the ordinary provision of the Service, the Parties may agree reasonable additional compensation reflecting the actual effort involved.

7. PERSONAL DATA BREACHES

The Provider shall maintain documented procedures for identifying, managing, investigating and remediating Personal Data Breaches.

Upon becoming aware of a Personal Data Breach affecting Personal Data Processed under this DPA, the Provider shall notify the Customer without undue delay and, wherever reasonably practicable, within seventy-two (72) hours after confirming that a reportable breach has occurred.

Such notification shall include all information reasonably available to the Provider concerning the nature of the incident, the categories of Personal Data affected, the likely consequences of the breach, the measures already implemented and any proposed remediation measures.

Where all relevant information cannot reasonably be provided simultaneously, the Provider may supply information in phases as it becomes available.

The Provider shall promptly investigate every confirmed Personal Data Breach and shall implement appropriate corrective actions designed to mitigate its effects and reduce the likelihood of recurrence.

Notification of a Personal Data Breach shall not constitute an admission of liability or fault.

8. SUB-PROCESSORS

The Customer grants the Provider a general authorisation to engage Sub-processors for the performance of the Services.

The Provider shall ensure that every Sub-processor is engaged under a written agreement imposing data protection obligations that are no less protective than those contained in this DPA insofar as applicable to the Processing entrusted to the relevant Sub-processor.

The Provider shall remain fully responsible for the performance of its Sub-processors' obligations under this DPA.

The current list of authorised Sub-processors shall be maintained in **Annex III**.

The Provider may appoint additional Sub-processors provided that it gives the Customer at least thirty (30) days' prior notice.

If the Customer reasonably objects to the appointment of a proposed Sub-processor on documented data protection grounds, the Parties shall cooperate in good faith to identify a commercially reasonable solution.

If no reasonable solution can be achieved, the Customer may terminate only the affected Services without penalty.

9. INTERNATIONAL TRANSFERS

The Provider shall not transfer Personal Data to a country or international organisation outside the European Economic Area unless such transfer is carried out in accordance with Chapter V of the GDPR.

Where the Provider or any authorised Sub-processor transfers Personal Data to a third country for which no adequacy decision has been adopted by the European Commission, the Provider shall ensure that appropriate safeguards have been implemented prior to such transfer.

Such safeguards may include the Standard Contractual Clauses adopted by the European Commission, an approved certification mechanism, Binding Corporate Rules or any other lawful transfer mechanism recognised under applicable Data Protection Law.

Where required by applicable law, the Provider shall conduct and periodically review an assessment of the legal framework applicable to the recipient jurisdiction in order to determine whether the implemented safeguards continue to ensure a level of protection essentially equivalent to that guaranteed within the European Union.

Where supplementary contractual, organisational or technical measures are reasonably necessary to ensure the lawfulness of a transfer, the Provider shall implement such measures before the transfer takes place.

The Provider shall promptly notify the Customer if it becomes aware that an applicable transfer mechanism can no longer be relied upon or if a competent authority challenges the lawfulness of a transfer affecting the Services.

10. AUDITS AND COMPLIANCE

The Provider shall maintain appropriate records demonstrating compliance with this DPA and shall make available to the Customer such information as is reasonably necessary to demonstrate compliance with Article 28 of the GDPR.

The Parties acknowledge that modern cloud services are operated within highly secure, multi-tenant environments where unrestricted physical access or customer-led inspections may compromise the security, confidentiality or availability of services provided to other customers.

Accordingly, the Customer agrees that the Provider may satisfy its audit obligations by making available appropriate independent audit reports, recognised certifications, compliance attestations, penetration testing summaries or equivalent documentation demonstrating compliance with applicable security standards.

Where such documentation does not reasonably satisfy the Customer's regulatory obligations, the Customer may request an additional audit.

Any such audit shall: a) be limited to matters directly relevant to the Processing carried out under this DPA; b) be conducted during normal business hours; c) be subject to reasonable prior written notice of not less than thirty (30) days; d) avoid unnecessary disruption of the Provider's business operations; e) preserve the confidentiality of information relating to other customers; and f) be carried out by an independent professional auditor bound by appropriate confidentiality obligations.

Unless the audit reveals a material breach of this DPA or applicable Data Protection Law, the Customer shall bear its own costs and reimburse the Provider for the reasonable internal costs incurred in facilitating the audit.

The Provider shall promptly remedy any material deficiencies identified during an audit.

11. RETURN AND DELETION OF PERSONAL DATA

Upon termination or expiration of the Agreement, the Customer shall remain responsible for exporting any Personal Data it wishes to retain using the functionalities made available through the Service.

Unless otherwise agreed in writing or required by applicable law, the Provider shall retain Personal Data for the limited period specified in the Agreement solely to facilitate Customer retrieval, disaster recovery and the orderly termination of the Services.

Following expiry of the applicable retention period, the Provider shall securely delete or irreversibly anonymise all remaining Personal Data under its control.

The obligation to delete Personal Data shall not apply where retention is required under applicable law or where Personal Data forms part of routine backup media

retained in accordance with the Provider's documented backup policies, provided that such information remains subject to appropriate technical and organisational safeguards and is not actively processed except where legally required.

Upon reasonable request, the Provider shall confirm completion of the deletion process.

12. GOVERNMENT ACCESS REQUESTS

If the Provider receives a legally binding request from a public authority requiring access to Personal Data Processed under this DPA, the Provider shall, to the extent legally permitted, promptly notify the Customer before disclosing the requested information.

The Provider shall review every such request to determine whether it is valid, proportionate and legally enforceable.

Where the Provider reasonably considers that a request exceeds the powers granted under applicable law or otherwise lacks a lawful basis, it shall use commercially reasonable efforts to challenge or limit the request before disclosing any Personal Data.

The Provider shall disclose only the minimum amount of Personal Data strictly required to comply with the applicable legal obligation.

Nothing in this Clause shall require the Provider to act contrary to applicable law.

13. LIABILITY

Each Party shall remain responsible for its respective obligations under applicable Data Protection Law.

Nothing contained in this DPA shall alter or expand the allocation of liability established under the Agreement except where expressly required by mandatory law.

The Provider shall be liable only for damages resulting directly from its own breach of this DPA or applicable Data Protection Law.

Where multiple parties are responsible for the same damage, liability shall be allocated between them in proportion to their respective responsibility for the event giving rise to the damage.

The limitations of liability established in the Agreement shall apply equally to this DPA except where mandatory law provides otherwise.

14. TERM

This DPA shall become effective on the Effective Date of the Agreement.

It shall remain in force for so long as the Provider continues to Process Personal Data on behalf of the Customer.

Termination of the Agreement shall automatically terminate this DPA, except for those provisions which by their nature are intended to survive termination, including those relating to confidentiality, deletion of Personal Data, liability and applicable law.

15. GOVERNING LAW

This Data Processing Agreement shall be governed by the governing law and jurisdiction provisions contained in the Agreement of which it forms an integral part.

ANNEX I
DESCRIPTION OF PROCESSING

Controller
The Customer identified in the applicable Order Form.

Processor
ATEBIZ

Subject Matter
Provision of the NEXTREPORTING Software-as-a-Service platform together with associated hosting, maintenance, support and Professional Services.

Duration
For the duration of the Agreement together with the applicable retention period established under the Agreement and this DPA.

Nature of the Processing
The Processing activities may include collection, recording, organisation, structuring, storage, consultation, retrieval, analysis, visualisation, adaptation, transmission, alignment, reporting, hosting, backup, deletion and any other operation strictly necessary for the provision of the Services.

Purpose
The Provider Processes Personal Data exclusively for the purpose of providing the Services requested by the Customer, maintaining the availability and security of the platform, delivering support services, implementing customer instructions and complying with applicable legal obligations.

Categories of Data Subjects
Depending upon the Customer's own use of the Services, Data Subjects may include employees, directors, officers, shareholders, consultants, contractors, suppliers, customers, prospective customers, authorised users, external advisers and other individuals whose Personal Data forms part of the Customer Data.

Categories of Personal Data
The categories of Personal Data may include identification data, professional contact information, employment information, user credentials, financial identifiers, accounting references, transaction-related information, audit logs, usage records and any other Personal Data uploaded by the Customer.

The Provider does not intentionally require or encourage the Processing of special categories of Personal Data.

Where the Customer nevertheless uploads such information, the Customer shall remain responsible for ensuring that an appropriate legal basis exists.

ANNEX II
TECHNICAL AND ORGANISATIONAL MEASURES

The Provider maintains an Information Security Management System designed to protect the confidentiality, integrity, availability and resilience of the Services.

Without prejudice to the continuous evolution of security practices, the Provider maintains measures addressing identity and access management, role-based access control, authentication mechanisms, encryption of data in transit and at rest where appropriate, infrastructure monitoring, security logging, vulnerability management, secure software development, malware protection, endpoint security, business continuity, disaster recovery, supplier risk management, personnel security, incident response and periodic security assessments.

The Provider regularly reviews its security measures in light of technological developments, emerging threats and recognised industry standards.

The Provider may update these measures provided that the overall level of protection is not materially reduced.

ANNEX III
AUTHORISED SUB-PROCESSORS

The Provider may engage carefully selected Sub-processors to support the delivery of the Services, including providers of cloud infrastructure, hosting services, content delivery networks, customer support platforms, monitoring solutions, communication services and cybersecurity services.

An up-to-date list of authorised Sub-processors shall be maintained by the Provider and made available to Customers through an online repository or other reasonable electronic means.

The Provider shall ensure that each Sub-processor is contractually bound by obligations affording a level of protection for Personal Data that is substantially equivalent to that established under this DPA.